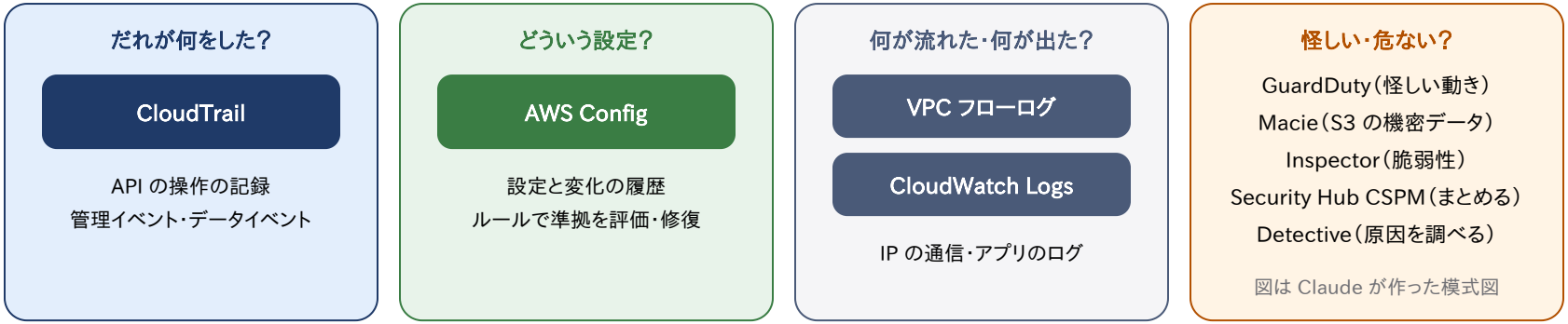
AWS SAA（SAA-C03）　分野1 セキュアなアーキテクチャの設計　#05

ログ・監査と脅威の検出

だれが何をしたかは CloudTrail、どういう設定かは Config、怪しい動きは GuardDuty。似た名前のサービスを「何を見るか」で分ける

各ページの下に、根拠にした AWS の公式ドキュメント（CloudTrail・Config・GuardDuty・Macie・Inspector・Security Hub CSPM・Detective・VPC フローログ・CloudWatch Logs・Artifact）を書いた（青い文字を押すと開く）。「」の中はドキュメントの原文どおり（日本語版は機械翻訳のため、語順が不自然なところもそのまま）。会社名や構成の例は Claude が作った例

全体像 試験ガイド タスク 1.2・1.3



試験ガイドの知識・スキル（要約）	このPDF
適切なユースケースを備えたセキュリティサービス（Cognito・GuardDuty・Macie など）[1.2]	**第3章（Cognito は #02）**
データアクセスとガバナンス／コンプライアンス要件を満たすよう AWS の技術を調整する[1.3]	**第1・2章**

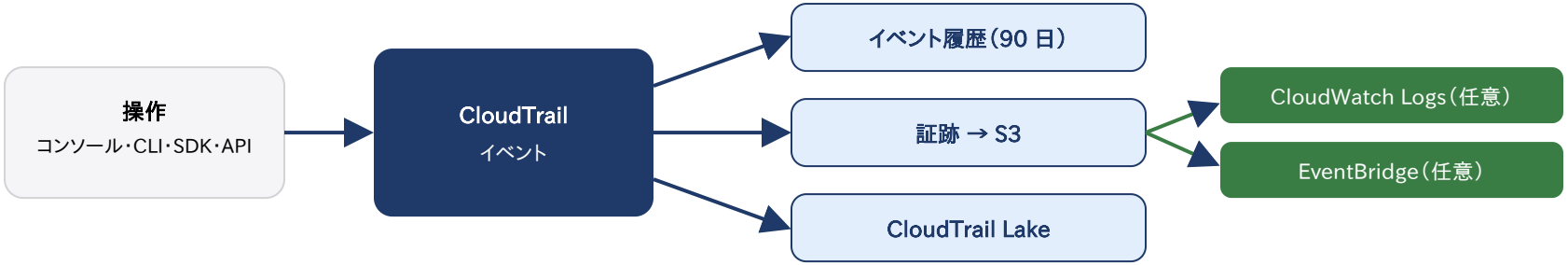
出典：AWS「コンテンツ分野 1: セキュアなアーキテクチャの設計」タスク 1.2・1.3

第1章

だれが何をしたか（CloudTrail）

操作はすべてイベントになる。90 日はタダで見られる。長く残す・まとめる・改ざんを確かめる方法を押さえる。

CloudTrail の3つの記録のしかた



	イベント履歴	証跡	CloudTrail Lake
中身	そのリージョンの管理イベント	選んだイベント（管理・データ・Insights）	選んだイベントをイベントデータストアに
期間	過去 90 日	S3 に置くかぎり	料金オプションで最長約 10 年など
料金	なし	管理イベントの1コピーは無料（S3 の保存料は別）	取り込み・保存・クエリに料金
使いどころ	最近の操作をすぐ調べる	長期保存・通知・ほかのツールで分析	SQL で長期の監査・分析

出典：とは AWS CloudTrail（「イベント履歴 の閲覧には CloudTrail の料金はかかりません。」「証跡を作成すると、進行中の管理イベントのコピーを 1 つ無料で CloudTrail から S3 バケットに配信できますが、Amazon S3 ストレージには料金がかかります。」）

管理イベント・データイベント・Insights イベント

	管理イベント	データイベント	Insights イベント
何の記録	リソースに対する管理の操作（コントロールプレーン）	リソースの上や中での操作	API の呼び出しの率・エラーの率の異常
例	`AttachRolePolicy`・`CreateSubnet`・`CreateTrail`・EC2 の起動	S3 の `GetObject`・`PutObject`・`DeleteObject`、Lambda の実行	ふだんより急に `RunInstances` が増えた
デフォルトで記録	**される**	**されない（量が多い）**	**されない**

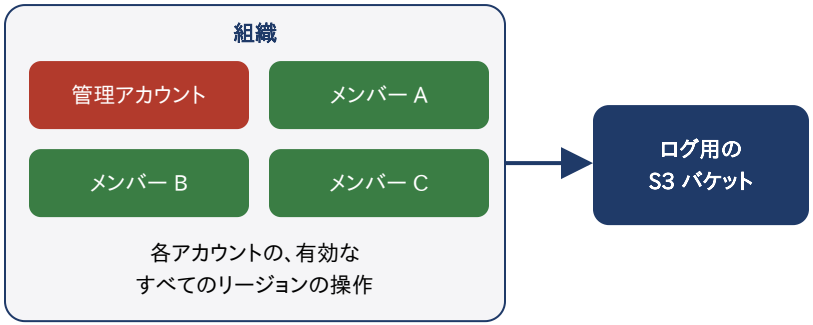
本番のひっかけ：「S3 のオブジェクトをだれが読んだか」は、証跡を作っただけでは残らない。データイベントを有効にする。

アラームにつなぐ：証跡を CloudWatch Logs や EventBridge に送ると、「IAM のポリシーが変わったら SNS で通知」のような仕組みが作れる。

出典：CloudTrail のコンセプト（「デフォルトでは、証跡とイベントデータストアは管理イベントをログ記録しますが、データイベントまたは Insights イベントは記録しません。」「データイベントは、多くの場合、高ボリュームのアクティビティです。」）／CloudTrail Insights の使用

もれなく・改ざんなく残す

組織の証跡 × マルチリージョン



組織の証跡は管理アカウント（または委任された管理者）が作る。メンバーアカウントのユーザーは、消す・止める・変えるができない。図は Claude が作った模式図。

守りたいこと	使うもの
全アカウントの記録を1か所に	**組織の証跡**
使っていないリージョンの操作も残す	**マルチリージョン証跡**
届いたあとに書き換えられていない証明	**ログファイルの整合性の検証**
90 日より長く、SQL で分析	**CloudTrail Lake**

整合性の検証のしくみ：SHA-256 のハッシュと、RSA のデジタル署名。気づかれずに変更・削除・偽造することが計算上できなくなる。セキュリティやフォレンシックの調査で重要。

出典：組織の証跡の作成（「組織の証跡では、組織内の管理アカウントとすべてのメンバーアカウントのイベントが記録されます。」）／CloudTrail ログファイルの整合性の検証（「検証されたログファイルは、セキュリティおよびフォレンシック調査で非常に重要です。」）

第2章

設定とネットワークの記録

Config は「リソースの今と昔の姿」。フローログは「流れた通信」。

CloudWatch Logs は「アプリが書いたログ」。

同じ出来事を CloudTrail と Config で見る

出来事：10/3 14:05 に、ユーザー tanaka が sg-web から「22 番を 0.0.0.0/0 から許可」のルールを足した（Claude が作った例）

CloudTrail のイベント

eventName: AuthorizeSecurityGroupIngress
userIdentity: tanaka / sourceIP / 時刻

→「だれが・いつ・どこから・何の操作を」

Config の設定の履歴

sg-web の設定：10/3 以前は 443 だけ → 以後は 443 と 22
関係：どの EC2・ENI に付いているか

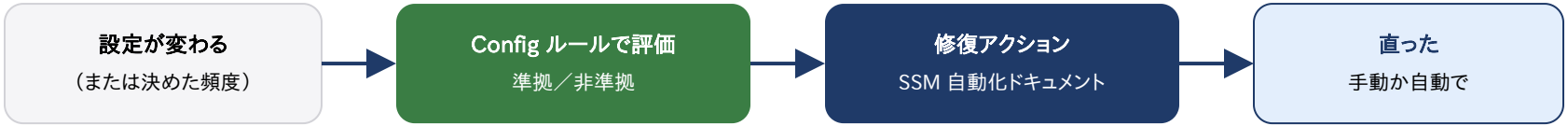
→「リソースがどういう状態で、どう変わったか」＋ルールで準拠を評価

Config の動き：リソースの作成・変更・削除を続けて記録し、設定のスナップショットと履歴を S3 に届ける。変化を SNS で知らせることもできる。

どちらでも止めない：CloudTrail も Config も「記録・評価」のサービス。危ない操作を事前に止めるのは SCP や IAM のポリシー（#01・#02）。

出典：AWS Config とは?（「AWS Config は、AWS アカウントにある AWS リソースに関する設定の詳細ビューを提供します。」「また、AWS Config はリソースの作成、変更、または削除を継続的に評価します。」）

Config ルール → 修復 → まとめて配る・まとめて見る



例：「パブリックな S3 バケット」を非準拠と評価 → 自動でパブリックアクセスをブロック（Claude が作った例）

しくみ	何をする	本番の言い回し
Config ルール	あるべき設定を決めて評価。AWS のマネージドルールと、自分で書くカスタムルール	「基準に合わないリソースを続けて見つける」
修復	非準拠のリソースを Systems Manager の自動化ドキュメントで直す	「見つけたら自動で直す」
コンフォーマンスパック	ルールと修復の一式を、アカウント・リージョン・組織にまとめて配る（YAML）	「PCI DSS 向けのルール一式を全社に」
アグリゲータ	複数アカウント・複数リージョンの設定と準拠のデータを1か所に集める	「全社の準拠状況を1画面で」

出典：AWS Config による非準拠リソースの是正（「AWS Config では、AWS Config ルール で評価されている非準拠のリソースを修復できます。」）／コンフォーマンスパック／マルチアカウントマルチリージョンのデータ集約

VPC フローログと CloudWatch Logs

VPC フローログ

項目	中身
記録するもの	ネットワークインターフェイスに出入りする IP の通信の情報（送信元・送信先・ポート・許可か拒否かなど）
記録しないもの	パケットの中身
送り先	CloudWatch Logs・S3・Data Firehose
性能への影響	なし（通信の経路の外で集める）
使いどころ	厳しすぎる SG のルールの診断、インスタンスに届く通信の監視

CloudWatch Logs

項目	中身
集めるもの	EC2・CloudTrail・Route 53 など、システム・アプリ・AWS のサービスのログ
できること	クエリで検索、フィルターでログからメトリクスを作る、機密データのマスキング
ログクラス	標準と、取り込みが安い低頻度アクセス

アラームの作り方：ログ →（フィルター）→ メトリクス → CloudWatch アラーム → SNS。「ERROR が 1 分に 10 回で通知」など。

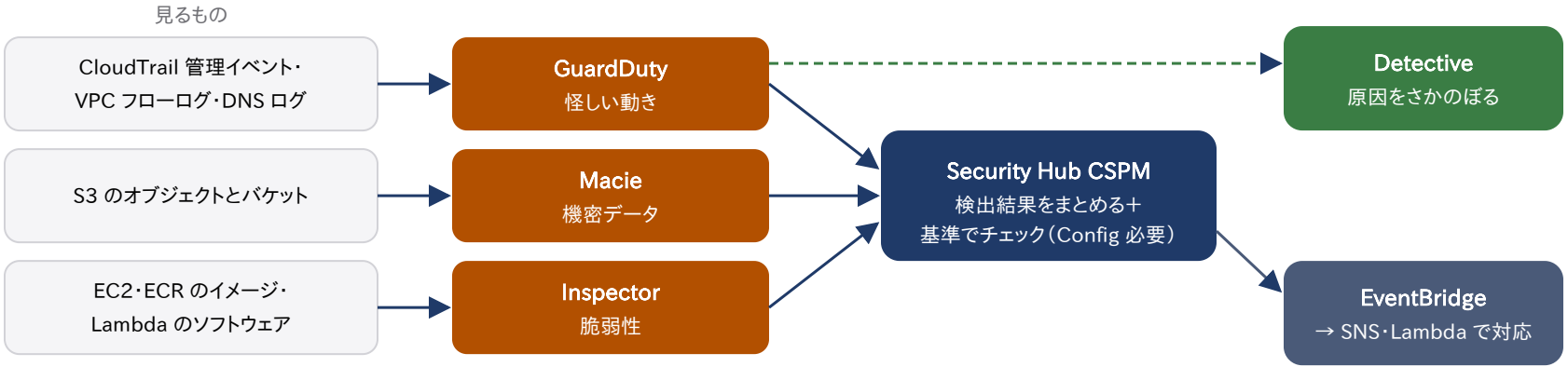
出典：VPC フローログを使用した IP トラフィックのログ記録（「フローログデータはネットワークトラフィックのパスの外で収集されるため、ネットワークのスループットやレイテンシーには影響しません。」）／Amazon CloudWatch Logs とは（「CloudWatch Logs を使用すると、使用するすべてのシステム、アプリケーション、AWS サービスからのログを 1 つの非常にスケーラブルなサービスに一元化できます。」）

第3章

脅威の検出と調査

見つける（GuardDuty・Macie・Inspector）、まとめる（Security Hub CSPM）、調べる（Detective）、対応する（EventBridge）。

5つのサービスの関係



図は Claude が作った模式図。GuardDuty の検出結果は EventBridge にも直接送られる

見つける3兄弟：動き＝GuardDuty、データ＝Macie、ソフトの穴＝Inspector。

まとめと調査：一覧と採点＝Security Hub CSPM、さかのぼって調べる＝Detective。

出典：AWS Security Hub CSPM の概要（「Security Hub CSPM は、のサービスにリンクされたルール AWS Config を使用して、ほとんどのコントロールのセキュリティチェックを実行します。」）／Amazon Detective とは（「Detective は、AWS リソースからログデータを自動的に収集します。」）

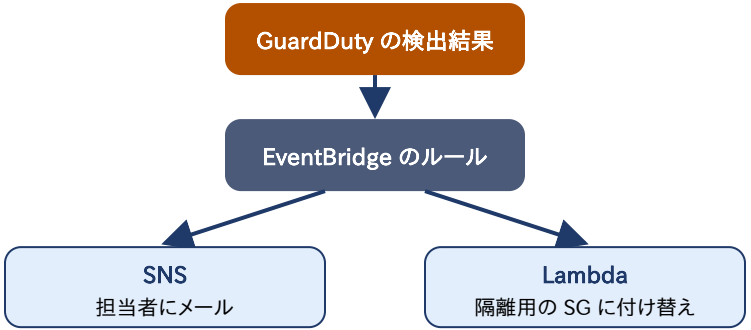
GuardDuty：有効にするだけで見張る

基本データソース	見えること（例）
CloudTrail 管理イベント	ふだんと違う場所からの API の呼び出し、ログの停止
VPC フローログ	悪いと知られた IP との通信
Route 53 Resolver の DNS クエリログ	悪いドメインの名前解決（マイニングなど）

見えることの例は Claude がまとめたもの。GuardDuty は独立した複製のストリームでログを読むので、証跡やフローログを自分で有効にしなくてよく、既存の設定にも影響しない。初めてのリージョンは 30 日間の無料トライアル。

> **見つけて知らせる：**GuardDuty は検出結果を出す。止める・隔離するのは EventBridge から呼ぶ Lambda などで自分で組む。

自動対応の例



構成は Claude が作った例

出典：GuardDuty 基本データソース（「GuardDuty は CloudTrail イベントを管理したり、既存の CloudTrail 設定に影響を与えたりすることはありません。」）／EventBridge を使用した GuardDuty 検出結果の処理（「検出結果をイベントとして自動的に公開 (送信) します。」）

選び分け：この要件ならこれ

要件	答え
だれがリソースを消したか調べる	CloudTrail
S3 のオブジェクトをだれが読んだか残す	CloudTrail のデータイベント
全アカウントの操作の記録を、止められないよう1か所に	組織の証跡
ログが改ざんされていないことを証明	ログファイルの整合性の検証
先月の時点の設定を見る／基準に合わない設定を見つける	Config／Config ルール
通信が SG で拒否されていないか	VPC フローログ
怪しい動き（認証情報の悪用・マイニング）を見つける	GuardDuty
S3 の個人情報を見つける	Macie
EC2・コンテナイメージの脆弱性	Inspector
検出結果を一元化し、CIS などの基準で採点	Security Hub CSPM
AWS 側の SOC・ISO のレポートを入手	AWS Artifact

出典：このPDFの各ページの資料

まとめ

CloudTrail
イベント履歴 90 日・証跡で S3・Lake で長期分析。データイベントはデフォルトで記録しない

Config
設定と関係の履歴。ルールで評価、修復は SSM。パックで配り、アグリゲータで集める

フローログ・CloudWatch Logs
IP の通信（中身なし）・アプリのログ。フィルター → メトリクス → アラーム

検出と調査
GuardDuty・Macie・Inspector が見つけ、Security Hub CSPM がまとめ、Detective が調べる

ひっかけ	正しくは
証跡は S3 の GetObject も記録	**データイベントは別に有効化**
Config ルールが違反を事前に拒否	**評価と修復。止めるのは SCP**
GuardDuty には先にフローログが必要	**不要。独立して読む**
Macie で EC2 の脆弱性	**Inspector**
Artifact で自社環境を採点	**Security Hub CSPM**

> 次の #06 からは分野2「弾力性に優れたアーキテクチャ」。まずは SQS・SNS・EventBridge などのメッセージングと疎結合を学ぶ。

出典：このPDFの各ページの資料